



MFA, сесије, сервиси и тајне

Контрола приступа кроз време, контекст и животни циклус

Проблем који решавамо

Идентитет није трајно доказан једном пријавом. Ризик радње, трајање сесије, врста уређаја и промена привилегија утичу на то колико је додатна потврда потребна. Оперативна безбедност зато прати приступ и након почетне аутентикације.

ПРОБЛЕМ

Шта може поћи по злу

Идентитет није трајно доказан једном пријавом. Ризик радње, трајање сесије, врста уређаја и промена привилегија утичу на то колико је додатна потврда потребна. Оперативна безбедност зато прати приступ и након почетне аутентикације.

ЗАШТО

Зашто је тема важна

Вишефакторска потврда и временски ограничене привилегије смањују последице украденог креденцијала. Управљање тајнама штити везе међу сервисима, где непажња често остане скривена јер нема корисничког екрана.

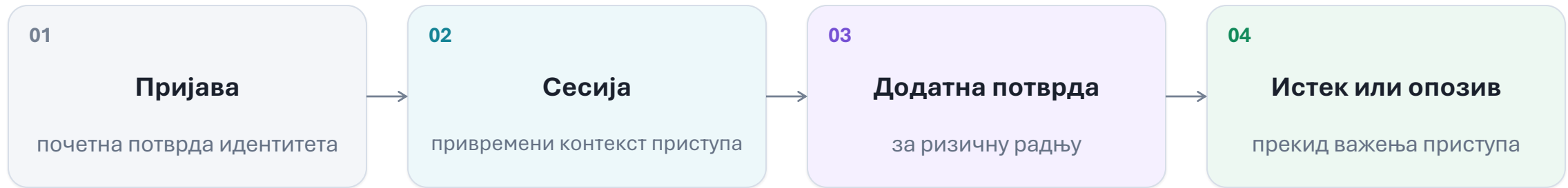
ИСХОД

Шта треба доказати

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

Четири појма граде једну одлуку

Сваки елемент одговара на друго питање и оставља другачији доказ.



КЉУЧНА ПОРУКА

Поверење се не чува заувек. Систем га обнавља или опозива када се промени ризик.

Пријава

почетна потврда идентитета

01

Сесија може изгубити важност пре планираног истека.

Питање: који улаз покреће ову одлуку?

02

Сесија је привремени доказ контекста, не трајна потврда поверења.

Питање: која граница мора бити видљива?

03

Истек ограничава трајање поверења чак и када нема видљивог инцидента.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Која радња заслужује додатну потврду идентитета и који догађај би требало да опозове постојећу сесију?

Сесија

привремени контекст приступа

01

Додатна потврда прати ризик радње, не само тип корисника.

Питање: који улаз покреће ову одлуку?

02

Step-up аутентикација има смисла када се ризик радње промени, а не као произвољна препрека за све кориснике.

Питање: која граница мора бити видљива?

03

Опозив реагује на конкретну промену ризика и не чека да сесија природно нестане.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Која радња заслужује додатну потврду идентитета и који догађај би требало да опозове постојећу сесију?

Додатна потврда

за ризичну радњу

01

Сервисни идентитет има мали, јасно оправдан опсег, као и људски идентитет.

Питање: који улаз покреће ову одлуку?

02

Сервисни налог добија исти третман као корисник: најмањи потребан опсег, рок важења и контролисану ротацију тајне.

Питање: која граница мора бити видљива?

03

Додатни фактор доказује присуство или поседовање независног средства, а не понавља само исту лозинку.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Која радња заслужује додатну потврду идентитета и који догађај би требало да опозове постојећу сесију?

Истек или опозив

прекид важења приступа

01

Истек ограничава трајање поверења чак и када нема видљивог инцидента.

Питање: који улаз покреће ову одлуку?

02

Опозив реагује на конкретну промену ризика и не чека да сесија природно нестане.

Питање: која граница мора бити видљива?

03

Додатни фактор доказује присуство или поседовање независног средства, а не понавља само исту лозинку.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Која радња заслужује додатну потврду идентитета и који догађај би требало да опозове постојећу сесију?

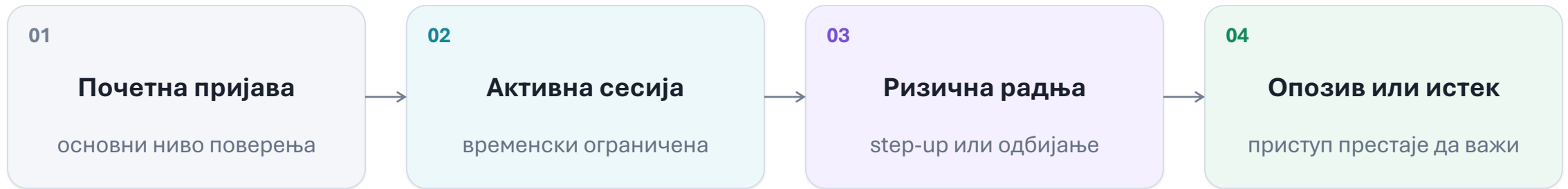
Различите врсте идентитета

Поређење служи да се разлике виде без тешке табеле и ситног текста.

Идентитет	Намена	Посебан ризик
Људски корисник	Интерактивне радње и одговорност.	Крађа креденцијала или преширока улога.
Сервисни налог	Комуникација међу компонентама.	Тајна без рока или превелик опсег.
Привремени приступ	Кратка ризична интервенција.	Право остане активно након потребе.
Администраторски налог	Измене са великим утицајем.	Недостатак додатне потврде и аудита.

Шема животног циклуса поверења

Поверење се не чува заувек. Систем га обнавља или опозива када се промени ризик.



ЗАДАТАК

За сваки корак наведите ко га покреће, ко доноси одлуку и који траг остаје.

Од тајне до безбедне употребе

Од описа проблема до одлуке која може да се провери.

КОНТЕКСТ

Од тајне до безбедне употребе

Безбедно управљање тајном почиње пре њеног првог коришћења. Потребно је знати власника, сврху, компоненту која је користи и начин ротације. Сама вредност тајне треба да остане ван кода, екрана и записа који нису за то намењени.

01

Тајна се издаје само идентитету који јој је стварно потребан.

02

Систем прати истек и планира ротацију пре прекида рада.

03

Логови бележе употребу и неуспех без приказивања вредности тајне.

04

Опозив ограничава последицу сумње да је тајна компромитована.

Приступ има рок и контекст

Три правила која треба да остану видљива у имплементацији и ревизији.

01

Сесија може изгубити важност пре планираног истека.

Јасно правило

02

Додатна потврда прати ризик радње, не само тип корисника.

Проверљива примена

03

Сервисни идентитет има мали, јасно оправдан опсег, као и људски идентитет.

Видљив доказ

Како се ова тема види у развоју

Тема се види у малим одлукама током развоја, не само у завршној документацији.

РАЗВОЈНИ КОНТЕКСТ

Од принципа до радног кода

Развојни тим унапред одређује које ситуације мењају ниво поверења: промена привилегије, приступ осетљивом податку или сумњива пријава. Тајне се референцирају из безбедног извора и никада се не преносе кроз код, тестне исписе или историју репозиторијума.

01

Именуј одлуку и њену границу.

02

Имплементирај проверу на серверу.

03

Додај позитиван и негативан доказ.

Пример: сесија после промене привилегије

Конкретан случај показује где опште правило постаје стварна одлука система.

СЦЕНАРИО

Пример: сесија после промене привилегије

Корисник се пријавио ујутру, а касније током дана добија виши ниво приступа. Ако систем не преиспита постојећу сесију, корисник може извршити ризичну радњу без додатне потврде која би била потребна да се пријављује у том тренутку. Обрнуто, одузета привилегија мора заиста да престане да важи, а не да чека крај дуготрајне сесије.

01

Сесија је привремени доказ контекста, не трајна потврда поверења.

02

Step-up аутентикација има смисла када се ризик радње промени, а не као произвољна препрека за све кориснике.

03

Сервисни налог добија исти третман као корисник: најмањи потребан опсег, рок важења и контролисану ротацију тајне.

Step-up не замењује проверу сесије и дозволе

Код почиње од исте леве ивице као наслов прозора и остаје читљив на пројектору.

```
1 public Result Approve(Session session, MfaProof proof)
2 {
3     if (session.IsExpired || session.IsRevoked)
4         return Result.Deny("invalid_session");
5     if (!proof.IsValidFor(session.SubjectId, clock.UtcNow))
6         return Result.Deny("step_up_required");
7     if (!session.Has("payment.approve"))
8         return Result.Deny("missing_permission");
9     return Result.Ok();
10 }
```

ШТА ЈЕ ВАЖНО

Додатна потврда подиже ниво поверења само за ограничену радњу и кратак временски прозор.

ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Опозив има предност над старим доказом

Негативан тест није споредан случај — он описује где право престаје.

```
1 [Fact]
2 public void Revoked_session_cannot_use_valid_old_mfa_proof()
3 {
4     var session = Session.Revoked(subject: "u-8");
5     var proof = MfaProof.ValidFor("u-8");
6
7     var result = guard.Approve(session, proof);
8
9     result.Reason.Should().Be("invalid_session");
10 }
```

ДОКАЗ

Чак и валидан стари MFA доказ не оживљава сесију која је у међувремену опозвана.

ПРОВЕРА

Промените једну чињеницу и очекујте јасан, стабилан разлог одбијања.

Доказ мора да одговори шта се догодило

Чува се довољно контекста за реконструкцију, али не и тајне или непотребни лични подаци.

```
1 {  
2   "subject": "u-8",  
3   "action": "payment.approve",  
4   "sessionState": "revoked",  
5   "assurance": "mfa",  
6   "outcome": "denied",  
7   "secretValueLogged": false  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Три грешке које треба препознати одмах

Свака делује практично у првој итерацији, али касније постаје скривена безбедносна граница.

01

Token третиран као вечна дозвола.

Нема јасног власника одлуке.

02

Администраторска права додељена без рока и прегледа.

Не постоји негативан сценарио.

03

Једна широка тајна дељена међу више независних сервиса.

Доказ не показује стварни исход.

Тајне као део архитектуре

Добар доказ је свеж, поновљив и довољно јасан да га други члан тима протумачи.

ОБРАЗЛОЖЕЊЕ

Тајне као део архитектуре

Тајна није конфигурациона вредност као свака друга. Њено излагање може дати приступ без видљивог корисничког екрана, нарочито између сервиса. Зато развојни процес дефинише одакле тајна долази, ко је користи, када се ротира и како се проверава да није случајно завршила у репозиторијуму или логу.

01

Сваки сервисни идентитет има сврху и најмањи потребан опсег.

02

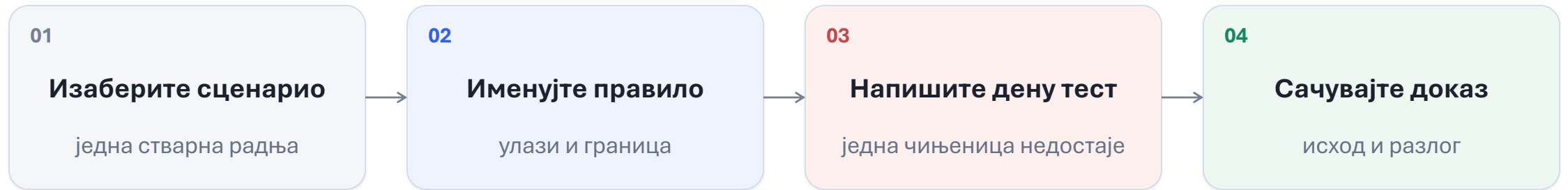
Ротација се планира пре истека, уместо да се чека прекид рада.

03

Тестови проверавају понашање при опозиву или истеку без приказивања стварних вредности тајне.

Мини вежба за пројекат

На једном сценарију повежите одлуку, имплементацију, негативни тест и доказ.

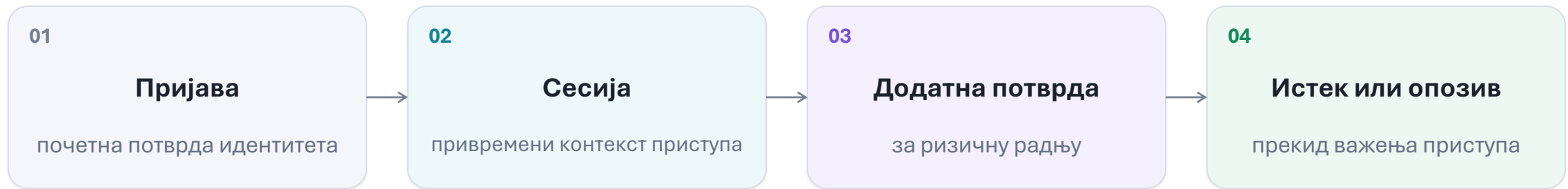


ЗАДАТАК ЗА ПРОЈЕКАТ

Примените тему „MFA, сесије, сервиси и тајне“ на додељену пројектну целину и припремите доказ који други члан тима може да понови.

Провера разумевања

Тема је савладана када одлуку можете да објасните без ослањања на назив framework-а.



ЗА ЗАВРШЕТАК

Која радња заслужује додатну потврду идентитета и који догађај би требало да опозове постојећу сесију?

Следећи корак: применити исти модел на једну реалну границу у сопственом пројекту.